420-1C2-DW · Threats and Risks · Class 1

Introduction to Threats and Risks

Topic 1 — six words, three properties, ten steps, two frameworks and one company to analyse

Thursday, October 22, 2026 · 6:00 – 10:00 pm · Online

AEC Cybersecurity: Prevention and Intervention (LEA.D8)

Competency EZ02 — Risk and threat analysis

Abbreviations: **AEC** (Attestation d'études collégiales, a Québec college-level professional program)

Asen Grozdanov
Cyber.SoHo Educational Hub

Tonight: six lessons in sixty minutes

1 Course presentation

0:00 – 0:08

You can explain EZ02, the evaluation, the tools and the formative Integrative Project.

2 Key vocabulary

0:08 – 0:20

You can use asset, threat, vulnerability, risk, impact, control in one risk statement.

3 The CIA triad

0:20 – 0:30

You can name the property an incident violates and rate it Low / Moderate / High.

4 The risk analysis process

0:30 – 0:42

You can follow ten steps and compute score = likelihood × impact.

5 NIST CSF 2.0 and ISO/IEC 27005

0:42 – 0:52

You can describe both frameworks and how they fit together.

6 The case organization

0:52 – 1:00

You can describe Kalmia and its first warning signs.

Abbreviations: **CIA** (Confidentiality, Integrity, Availability) · **CSF** (Cybersecurity Framework) · **ISO/IEC** (International Organization for Standardization / International Electrotechnical Commission) · **NIST** (National Institute of Standards and Technology)

Legal and ethical notice — read before any lab

- Educational material — Cyber.SoHo / Asen Grozdanov. © 2026 Cyber.SoHo. All rights reserved.
- Use only in an isolated, authorized lab environment, against the targets an exercise designates.
- Unauthorized access may be a criminal offence (Criminal Code, ss. 342.1, 342.2, 430(1.1), 184).
- Rule of this course (section 7.3): study threat information — never interact with live malicious infrastructure or its operators.
- Scan only designated lab targets (section 7.6); never test a real organization without written authorization (Annex D).
- Check every link before clicking — VirusTotal, Google Safe Browsing (section 14.2, Annex C).
- No recording or screen capture of classes without written permission (section 17).
- Full terms: Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy v2.0 (link in the module).

§

Section 7.3 — the rule of this course

"Study threat information; never interact with live malicious infrastructure or its operators."

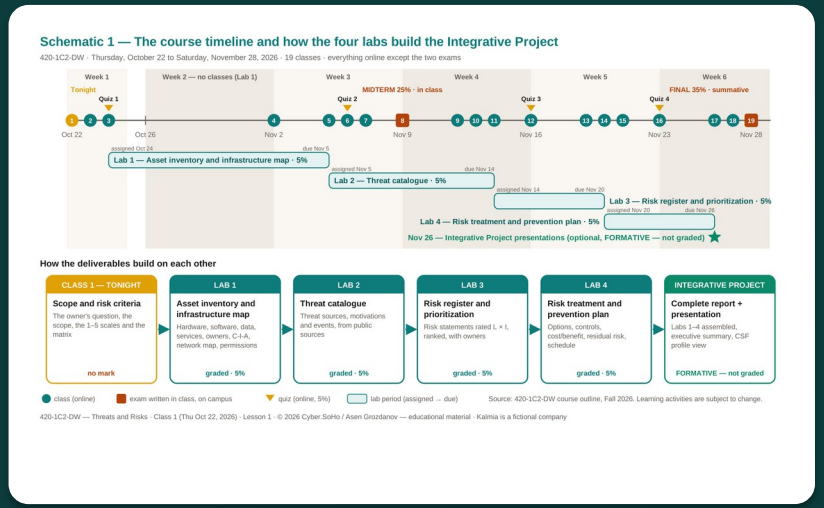
7.6	Scan only the designated lab targets
Annex C	Check every link before you click
17	No recording without written permission
Annex D	Written authorization for any real test

1

Lesson 1 · 0:00 – 0:08

Course presentation — objectives, evaluation, tools and the Integrative Project

- Objectives and competency EZ02
- Evaluation: quizzes, labs, exams
- Tools and information sources
- The Integrative Project — FORMATIVE



Schematic 1 — The course timeline and how the four labs build the Integrative Project

What this course trains — competency EZ02

- EZ02 — Risk and threat analysis, covered in its entirety
- 75 hours · ponderation 2–3–2 · 19 classes in 6 weeks
- For a whole network of different platforms, with analysts, network administrators and managers
- Public sources: newsletters, advisories, frameworks
- Private sources: inventory, penetration-test, compliance, incident and monitoring reports, policies
- Four learning outcomes:
  - identify and represent all information assets and their permissions
  - identify internal and external threats
  - identify risk factors; assess probability and severity
  - propose solutions that mitigate risks and eradicate threats

EZ02

risk and threat analysis — the whole competency

75 h

ponderation 2–3–2

19

classes, Oct 22 – Nov 28

4 labs

one company: Kalmia

How you are evaluated (1/2) — components

Component	When	Weight
Quizzes 1 – 4	Oct 24 · Nov 6 · Nov 16 · Nov 23 — online	4 × 5%
Lab 1 — Asset inventory and infrastructure map	Due Thu Nov 5	5%
Lab 2 — Threat catalogue	Due Sat Nov 14	5%
Lab 3 — Risk register and prioritization	Due Fri Nov 20	5%
Lab 4 — Risk treatment and prevention plan	Due Thu Nov 26	5%
Midterm Exam (Topics 1–4)	Mon Nov 9, 6–10 pm — IN CLASS	25%
Final Exam (Topics 1–7) — summative	Sat Nov 28, 2–5 pm — IN CLASS	35%
Integrative Project report + presentation	**Thu Nov 26 — online, optional**	**FORMATIVE**

Where the 100% comes from



Integrative Project report and presentation: 0% — FORMATIVE (feedback only)

How you are evaluated (2/2) — the rules

- Passing grade of the course: 60%
- The Final Exam is summative: it must be passed to pass the course
- Late work: −10% per day; not accepted 7 days after the due date
- Missed test with a valid reason: a make-up can be arranged
  - absence of 5 days or less: no medical certificate needed
  - longer absence: medical certificate required
- Literacy: up to 10% may be deducted (**ISEP** (Institutional Student Evaluation Policy))
- Cheating or plagiarism: failure of the work, possibly of the course (**ISEP**)
- Midterm and Final on campus; everything else online

60%

passing grade of the course

35%

Final Exam — summative, must be passed

−10%

per day late; refused after 7 days

≤ 10%

deduction for language (**ISEP**)

Tools and information sources

- Public: Canadian Centre for Cyber Security, **CVE** (Common Vulnerabilities and Exposures), MITRE **ATT&CK** (Adversarial Tactics, Techniques and Common Knowledge)
- Method: **NIST** (National Institute of Standards and Technology) **CSF** (Cybersecurity Framework) 2.0, **NIST SP** (Special Publication) 800-30, **ISO/IEC** (International Organization for Standardization / International Electrotechnical Commission) 27005
- Private (fictional, for Kalmia): inventory template, network data, penetration-test, compliance, incident and monitoring reports, policies
- Software: spreadsheet (Excel or LibreOffice Calc), diagrams.net or Visio, **Nmap** (Network Mapper) in the lab environment
- Quizzes on the course's online platform
- Required reading: free **BAnQ** (Bibliothèque et Archives nationales du Québec) account → O'Reilly, LinkedIn Learning
- Rule 7.3: study threat information; never interact with live malicious infrastructure

Spreadsheet

Excel or LibreOffice Calc — inventory and risk register

Diagrams

diagrams.net (free) or Visio — network maps

Nmap

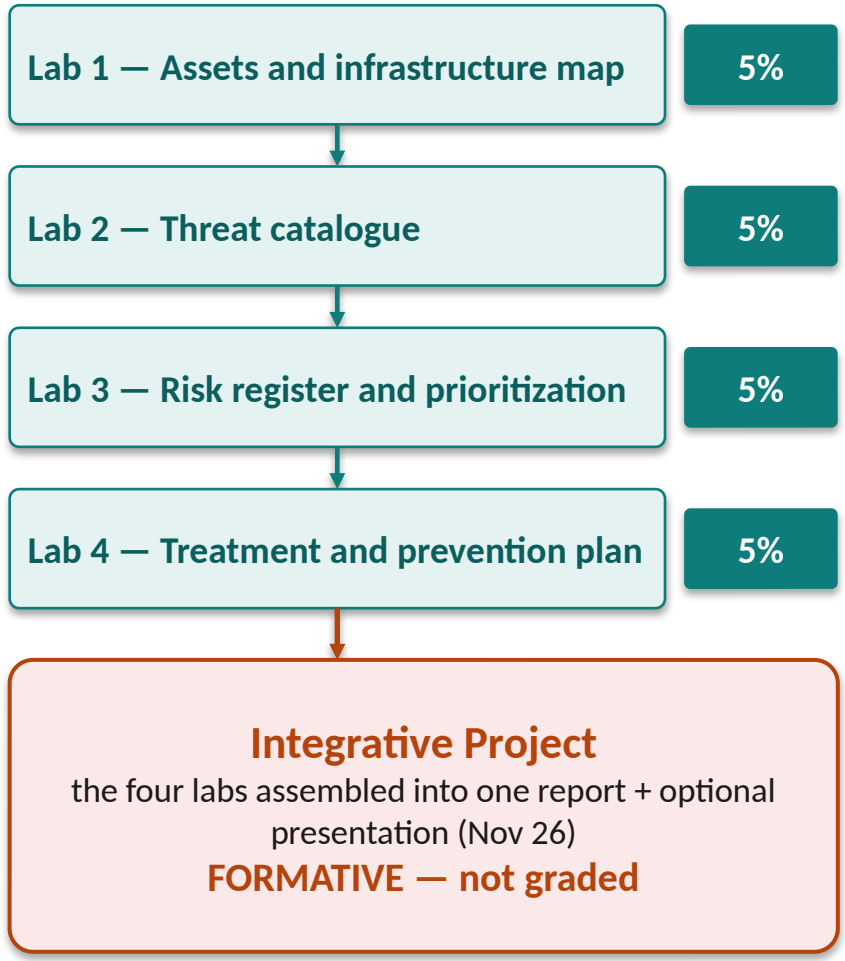
In the lab environment only, from Topic 2 (section 7.6)

BAnQ account

Free — opens O'Reilly and LinkedIn Learning

The Integrative Project — four labs, one company, FORMATIVE

- A complete risk analysis of Kalmia Coffee Roasters (fictional)
- Built in four parts, one per lab — each lab graded 5%
- Lab 1 → assets and infrastructure map
- Lab 2 → threat catalogue
- Lab 3 → risk register and prioritization
- Lab 4 → treatment and prevention plan
- Assembled report + optional presentation (Nov 26): FORMATIVE — not graded
- Purpose: feedback, exam practice, a portfolio document



Real-life example 1 — from the owner's question to the scope

Nadia Roy: “What could stop us from selling coffee next week, and what would it cost us?”

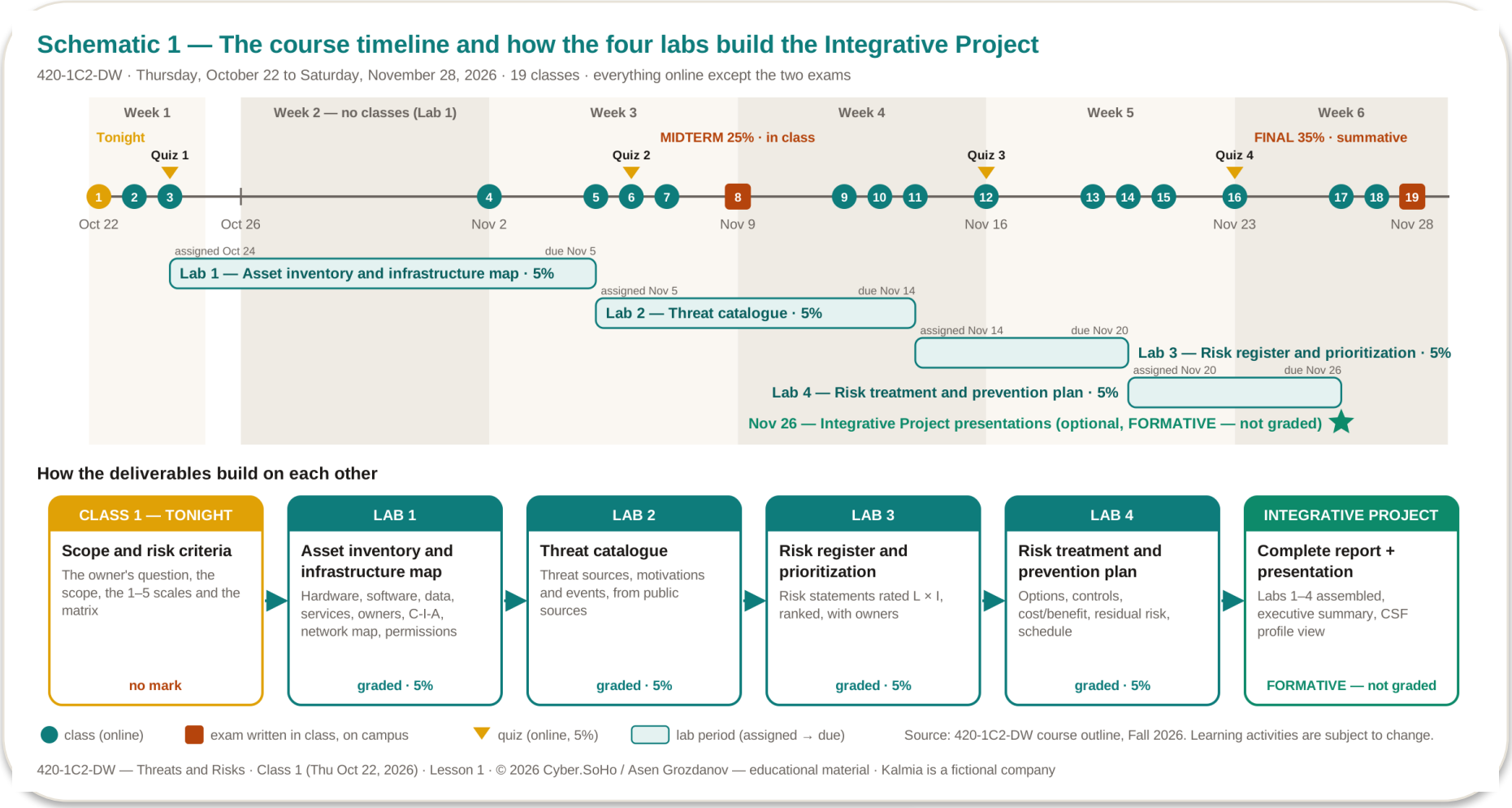
Item	Decision	Why
Four sites, NAS-01, web shop	In scope	Kalmia owns or controls them; they hold its information
Microsoft 365, **POS** (point of sale) cloud, loyalty, payroll	In scope as services used	Kalmia's information is in them
Payment processor, providers' data centres	Dependency	Kalmia relies on them but cannot assess them
Espresso machines (not connected)	Out of scope	No information
Staff phones used for e-mail	To confirm	An access path to Kalmia's mail

Owns or controls it?
Kalmia owns, controls or configures it

Holds Kalmia information?
It stores, processes or transmits it

Would its failure stop sales?
Sales or production stop without it

Schematic 1 — Course timeline and how the labs build the project

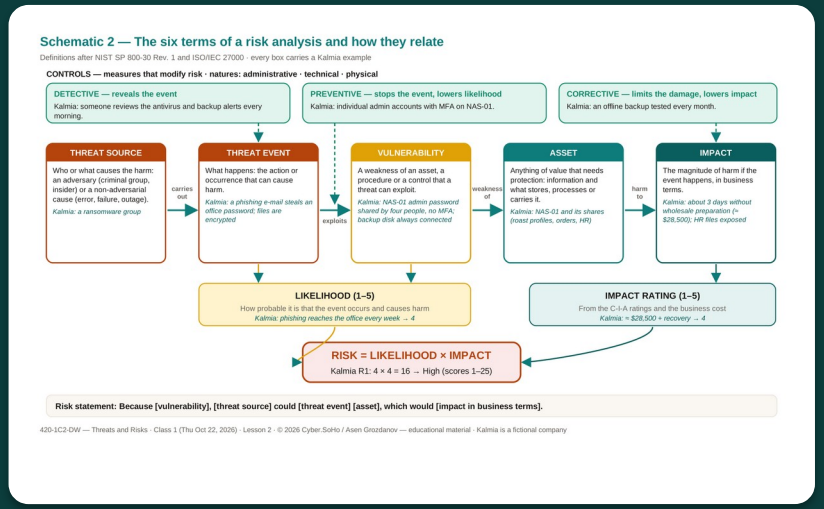


2

Lesson 2 · 0:08 – 0:20

Key vocabulary — asset, threat, vulnerability, risk, impact, control

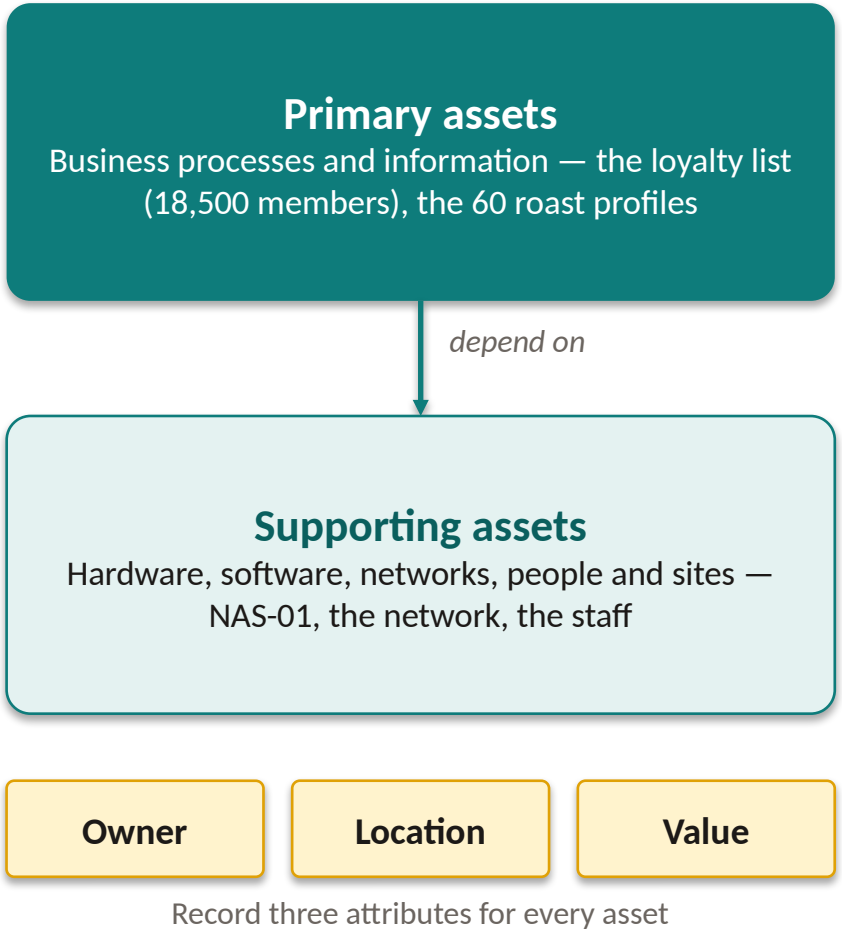
- Asset · Threat · Vulnerability
- Risk · Impact · Control
- How they connect
- The risk statement



Schematic 2 — The six terms and how they relate

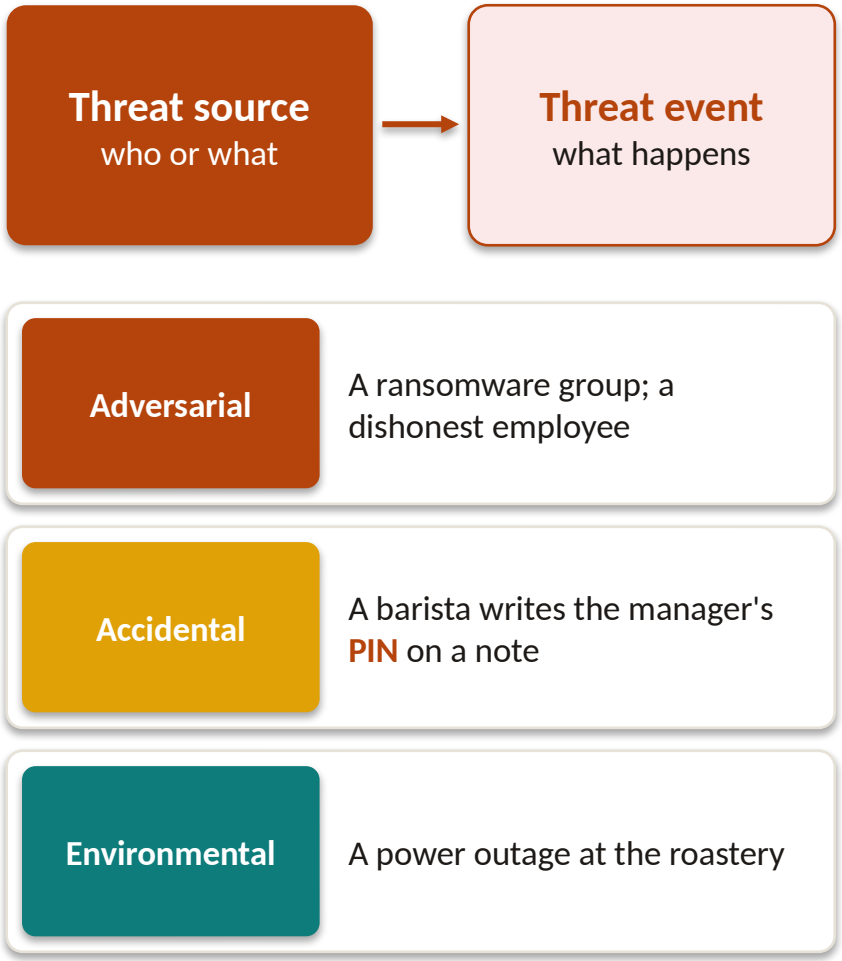
Asset

- Anything of value to the organization that needs protection
- Information, and everything that stores, processes or carries it
- Primary assets: business processes and information
- Supporting assets: hardware, software, networks, people, sites
- Record for each asset: owner · location · value
- Kalmia: loyalty member list and roast profiles (primary); NAS-01 (supporting)



Threat

- A potential cause of an unwanted event that can harm an asset
- Threat source: who or what — adversarial (criminal, insider) or not (error, failure, outage)
- Threat event: what happens — phishing, encryption, skimming script, deletion
- A threat exists whether or not you are vulnerable
- You rarely control the source — you control your exposure
- Kalmia: ransomware group · barista who writes down the **PIN** (personal identification number) · power outage



Vulnerability

- A weakness in an asset, a procedure or a control that a threat can exploit
- Technical · procedural · human · physical
- Predisposing condition: makes exploitation easier (a flat network)
- Exploit: to use a vulnerability — also the code or technique that does it
- Public software vulnerabilities receive a **CVE** (Common Vulnerabilities and Exposures) identifier
- Kalmia: ROAST-PC on Windows 10 · shared NAS-01 password · 4 outdated plugins

Technical

ROAST-PC on Windows 10; 4 outdated web shop plugins

Procedural

No offboarding: accounts removed “when someone remembers”

Human

Staff never trained to recognise phishing

Physical

An unlocked server closet

Risk

- The possibility that a threat exploits a vulnerability and harms an asset
- Measured by likelihood and impact (**NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-30)
- Risk score = Likelihood (1–5) × Impact (1–5) → 1 to 25
- No asset value, no threat, or no vulnerability → the risk falls
- A risk is not a threat: “ransomware group” ≠ “NAS-01 encrypted, 3 days lost”
- Inherent risk (before controls) · residual risk (after controls)

Risk = Likelihood × Impact

1 – 5	1 – 5	1 – 25
likelihood	impact	score

No asset value, no threat or no vulnerability
→ the risk falls
Inherent risk: before controls · Residual risk: after controls

Impact

- The magnitude of harm if the event happens
- Five dimensions: operations · finances · legal and regulatory · reputation · people and safety
- Not usable: “the impact is high”
- Usable: “no wholesale preparation for 3 days — about $9,500 of sales per day — **HR** (human resources) folder possibly exposed”
- Impact and likelihood are independent: rare can be catastrophic, frequent can be trivial

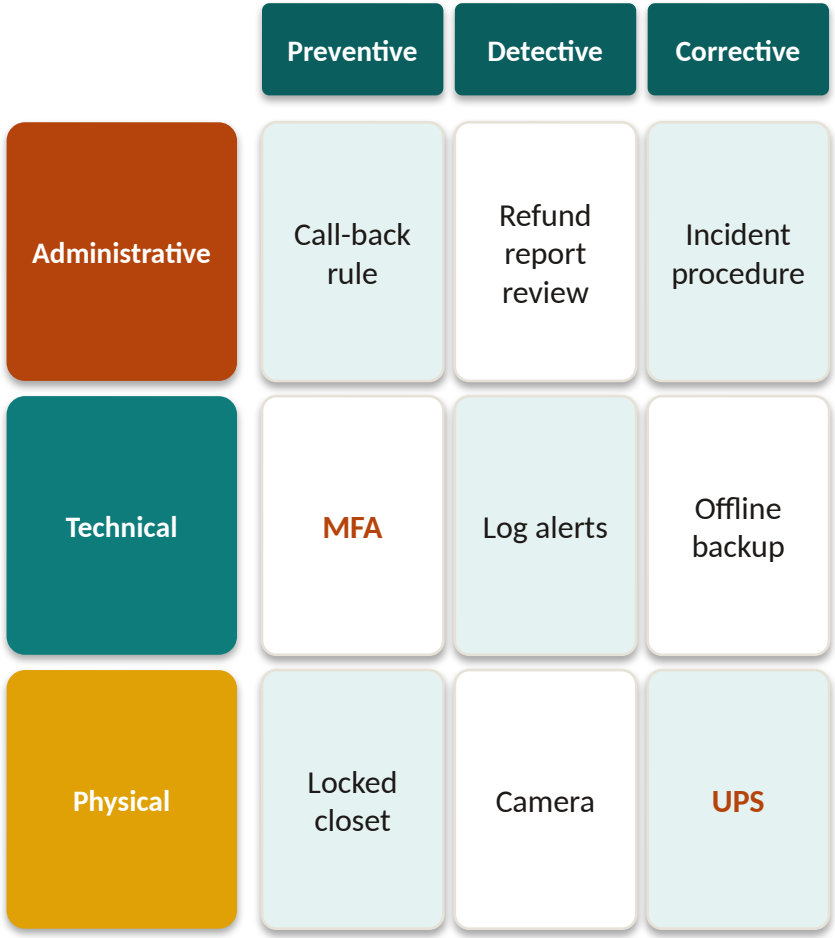
Five dimensions of impact

Operations	Wholesale preparation stops for 3 days
Finances	≈ $9,500 of sales per working day
Legal	Assessment for a declaration to the **CAI**; **PCI DSS**
Reputation	Customers who leave
People	Health and safety of staff and customers

Abbreviations: **CAI** (Commission d'accès à l'information du Québec) · **PCI DSS** (Payment Card Industry Data Security Standard)

Control

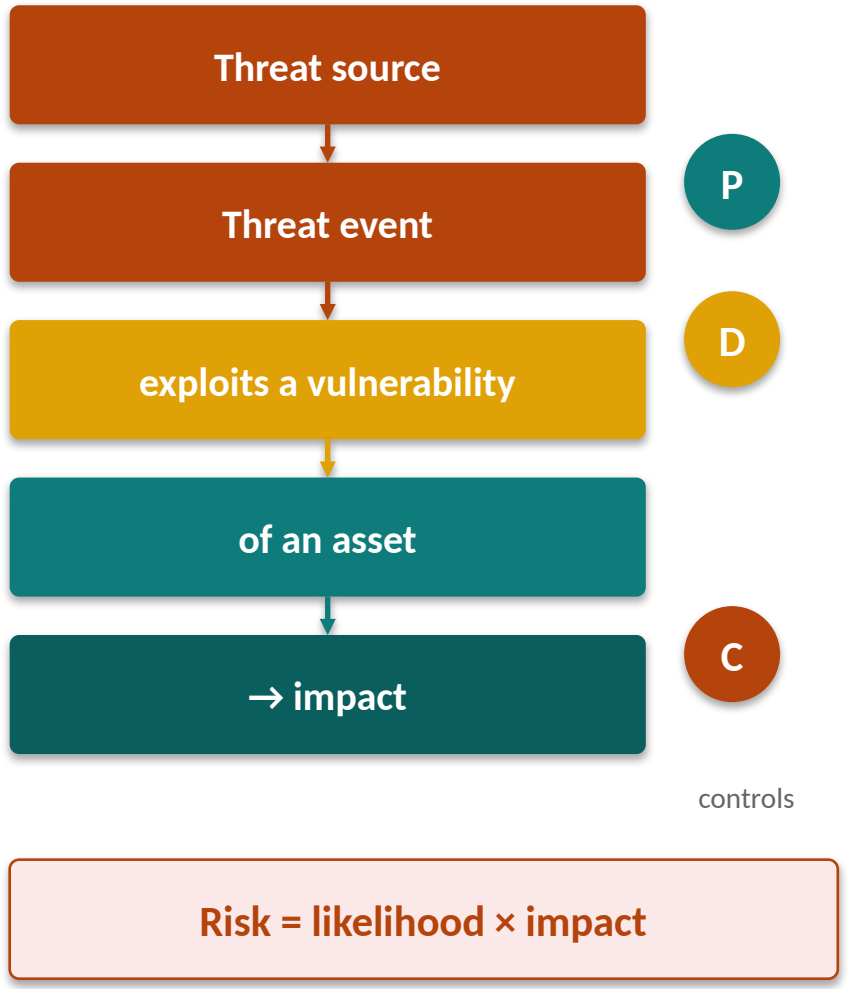
- A measure that modifies risk — lowers likelihood, impact, or both
- By nature: administrative · technical · physical
- By function: preventive · detective · corrective (+ deterrent, compensating, directive in Topic 6)
- Record existing controls before rating any risk
- Kalmia: **MFA** (multi-factor authentication) on 2 admin accounts only · nightly backup to a disk that ransomware can reach



Abbreviations: **UPS** (uninterruptible power supply)

How the six words connect — the risk statement

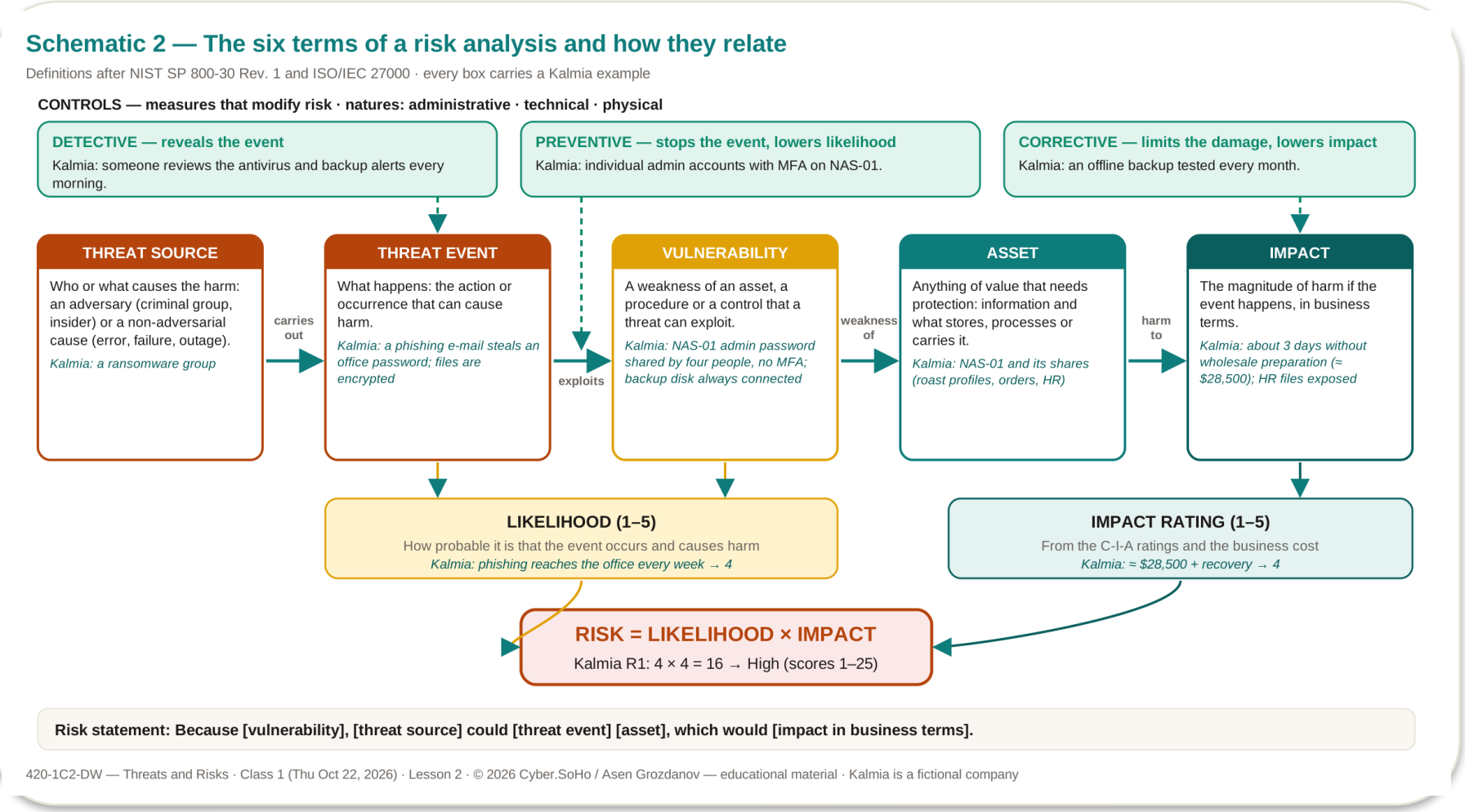
- Asset has value → vulnerability is its weakness → threat exploits it → impact
- Likelihood × impact = risk; controls act on likelihood, detection or impact
- Template: Because [vulnerability], [threat source] could [threat event] [asset], which would [impact]
- Example: Because NAS-01 has one shared admin password without **MFA** (multi-factor authentication) and its only backup stays plugged in, a ransomware group that phishes an office employee could encrypt the shared files and the backup, which would stop wholesale preparation for about three days (≈ $28,500)



Real-life example 2 — three scenarios, six words each

Term	A — NAS-01	B — café POS (point of sale)	C — web shop
Asset	NAS-01 and its shares	**POS** and refund function	Checkout page
Threat	Ransomware group / phishing	Dishonest employee / fake refunds	Criminal group / skimming script
Vulnerability	Shared admin password, backup connected	Shared manager **PIN** (personal identification number)	4 outdated plugins, no **MFA** (multi-factor authentication)
Existing control	Backup to attached disk	Refund log nobody reads	Host's daily backups
Impact	≈ 3 days, ≈ $28,500; **HR** (human resources) exposed	≈ $3,000; records unreliable	Card data; Law 25; holiday closure
Add control	Individual admin + **MFA**; offline backup	Individual PINs; weekly review	Auto-updates; **MFA**; page monitoring

Schematic 2 — The six terms and how they relate

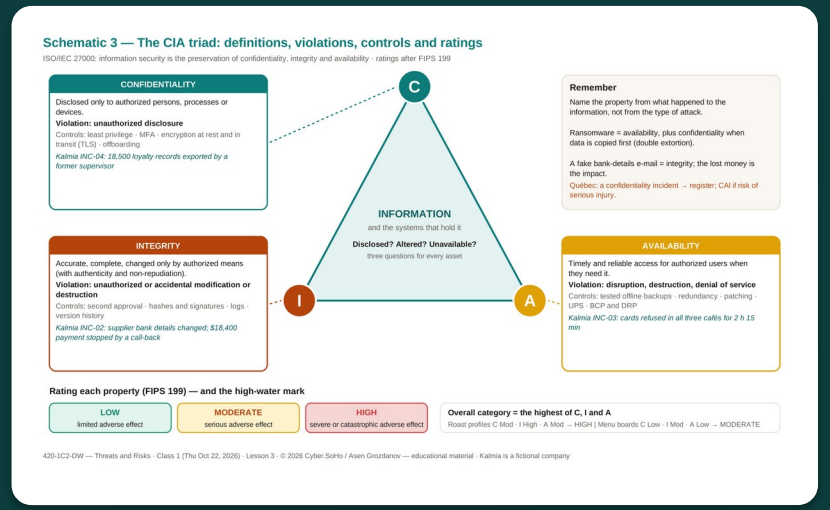


3

Lesson 3 · 0:20 – 0:30

The CIA triad — confidentiality, integrity, availability

- Confidentiality
- Integrity
- Availability
- Rating Low / Moderate / High and the high-water mark

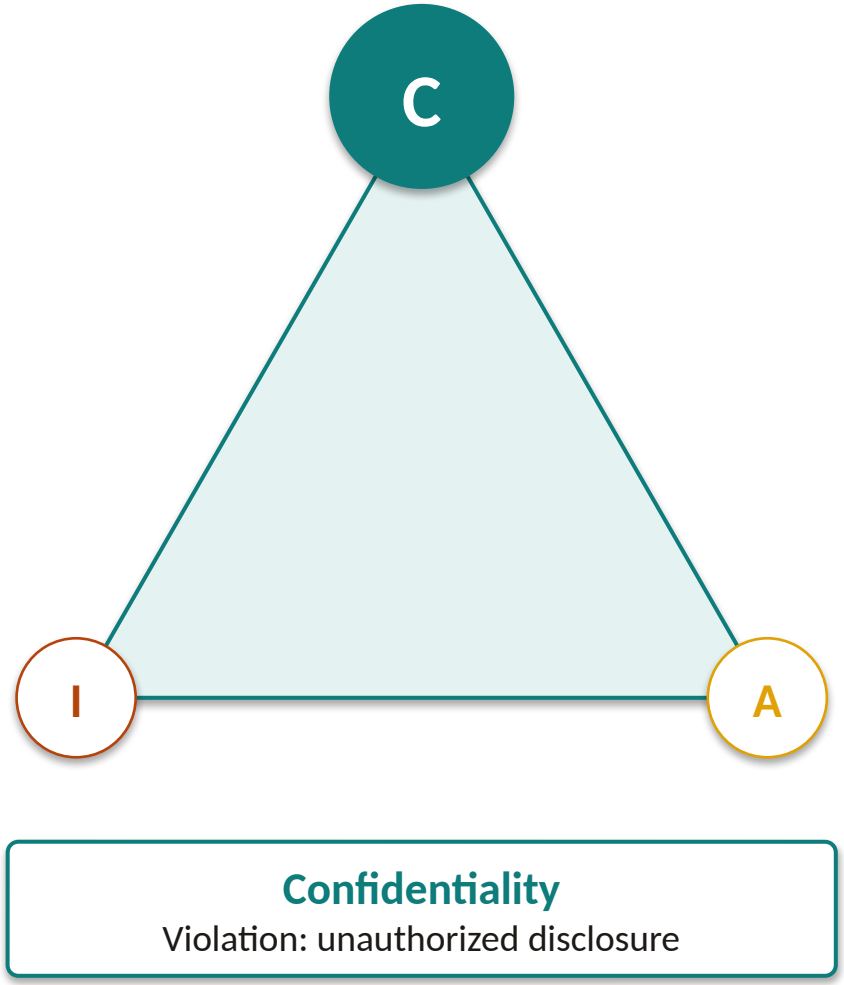


Schematic 3 — The CIA triad: definitions, violations, controls and ratings

Abbreviations: **CIA** (Confidentiality, Integrity, Availability)

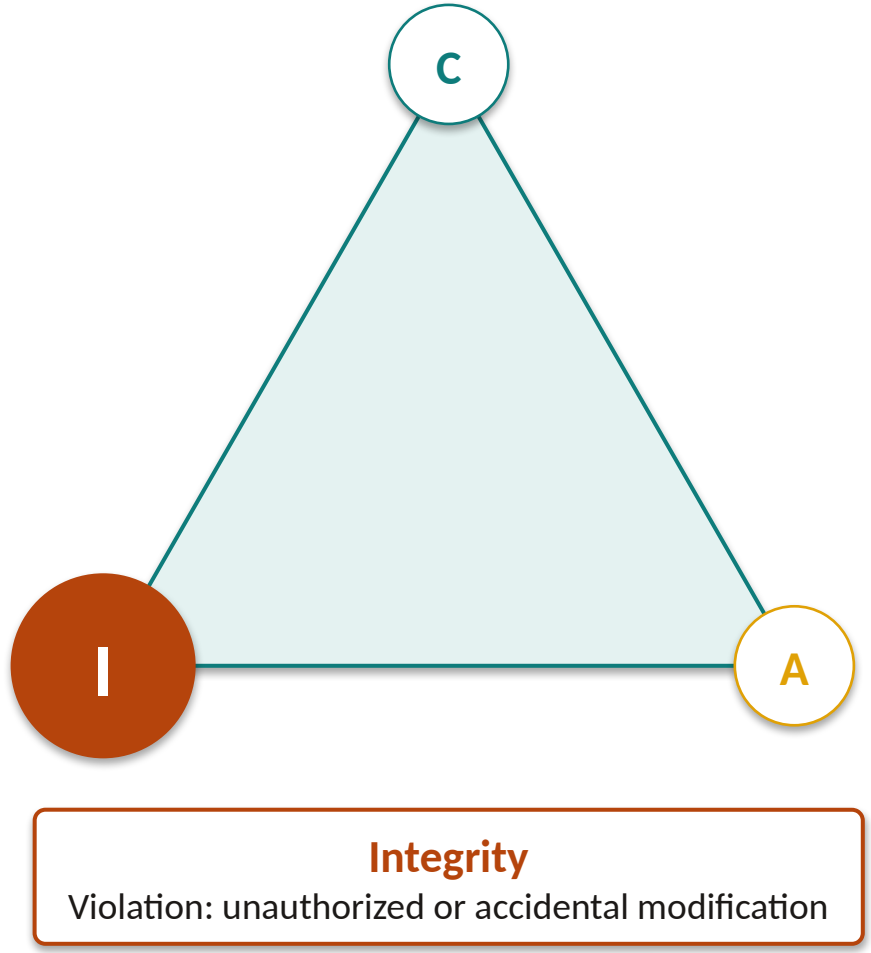
Confidentiality

- Disclosed only to authorized persons, processes or devices
- Violation: unauthorized disclosure
- Kalmia (INC-04): a former supervisor exports 18,500 loyalty records
- Controls: least privilege · **MFA** (multi-factor authentication) · encryption at rest and in transit (**TLS** (Transport Layer Security)) · classification · offboarding
- Québec: a confidentiality incident → register; if risk of serious injury → notify the **CAI** (Commission d'accès à l'information du Québec) and the persons concerned



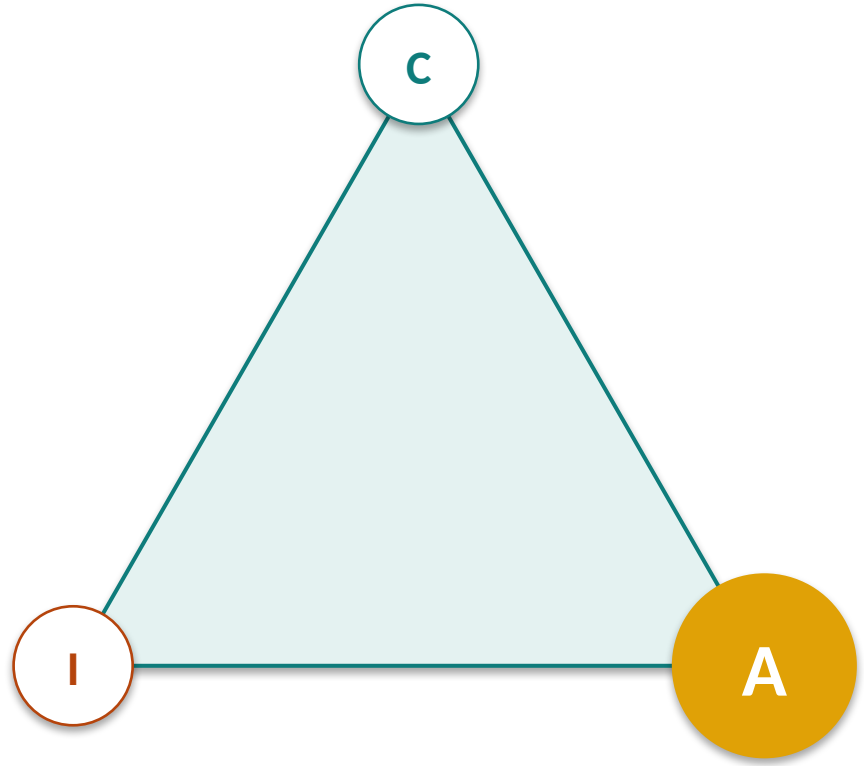
Integrity

- Accurate, complete, changed only by authorized means
- Includes authenticity and non-repudiation
- Violation: unauthorized or accidental modification or destruction
- Kalmia (INC-02): fake “new banking details” → $18,400 payment scheduled, stopped by a call-back
- Also: a modified roast profile burns 300 kg; a price changed from $18.99 to $1.89
- Controls: second approval · validation · hashes and signatures · logs · version history · backups



Availability

- Timely and reliable access for authorized users when they need it
- Violation: disruption, destruction, denial of service
- Kalmia (INC-03): **POS** (point of sale) refuses cards in 3 cafés, 08:05–10:20 — about $1,000 lost
- Also: ransomware on NAS-01 · **DDoS** (distributed denial of service) on the web shop · power failure
- Controls: tested offline backups · redundancy · patching · **UPS** (uninterruptible power supply) · **BCP** (Business Continuity Plan) and **DRP** (Disaster Recovery Plan)
- **RTO** (recovery time objective): how fast it must be back · **RPO** (recovery point objective): how much recent data may be lost



Availability
Violation: disruption, destruction, denial of service

Rating C, I and A — and the high-water mark

Kalmia asset	C	I	A	Overall
Loyalty member list	High	Moderate	Low	High
Roast profiles	Moderate	High	Moderate	High
Web shop and checkout	Moderate	High	High	High
POS (point of sale) service	Moderate	Moderate	High	High
Digital menu boards	Low	Moderate	Low	Moderate
Guest Wi-Fi	Low	Low	Low	Low

FIPS 199 levels

- **Low** — Limited adverse effect
- **Moderate** — Serious adverse effect
- **High** — Severe or catastrophic adverse effect

High-water mark

Overall = the highest of C, I and A

C Low · I High · A Moderate → High

Abbreviations: **FIPS** (Federal Information Processing Standard)

Real-life example 3 — three entries from Kalmia's incident notes

Entry	What happened	Property	Rating
INC-02 · Jun 9	Look-alike e-mail: “updated banking details”; account changed; $18,400 payment stopped by a call-back	Integrity	High
INC-03 · Aug 22	**POS** (point of sale) cloud refuses cards in all three cafés, 08:05–10:20; about $1,000 lost	Availability	Moderate
INC-04 · Sep 18	Former supervisor exports 18,500 loyalty records from an account never disabled	Confidentiality	High

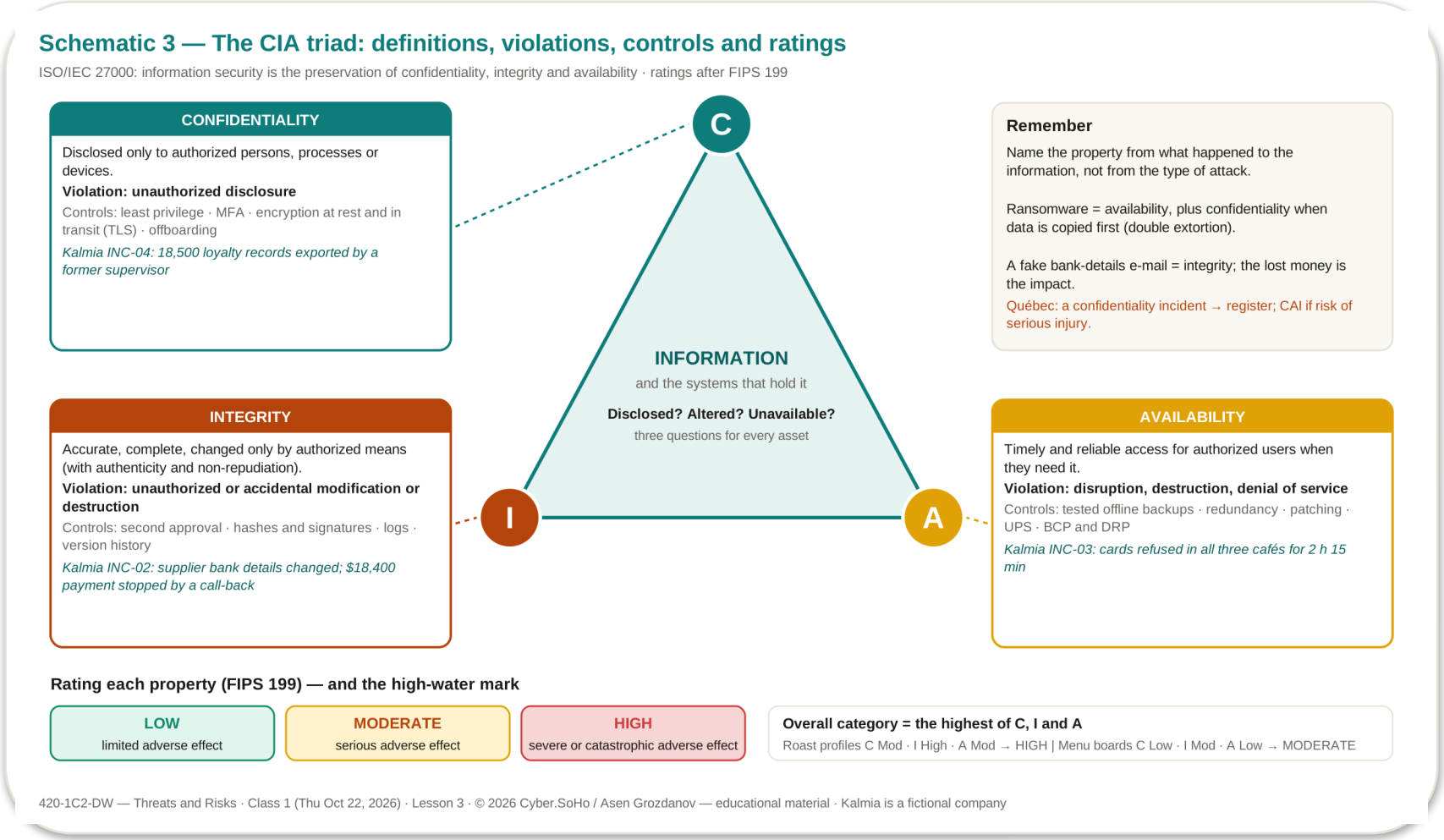
INC-02 → integrity rule
Every change of bank details: call-back on a known number + a second approver

INC-03 → availability plan
Offline payment mode and a written procedure for outages

INC-04 → confidentiality duty
Offboarding checklist; record the incident; Nadia Roy assesses a declaration to the **CAI**

Abbreviations: **CAI** (Commission d'accès à l'information du Québec)

Schematic 3 — The CIA triad



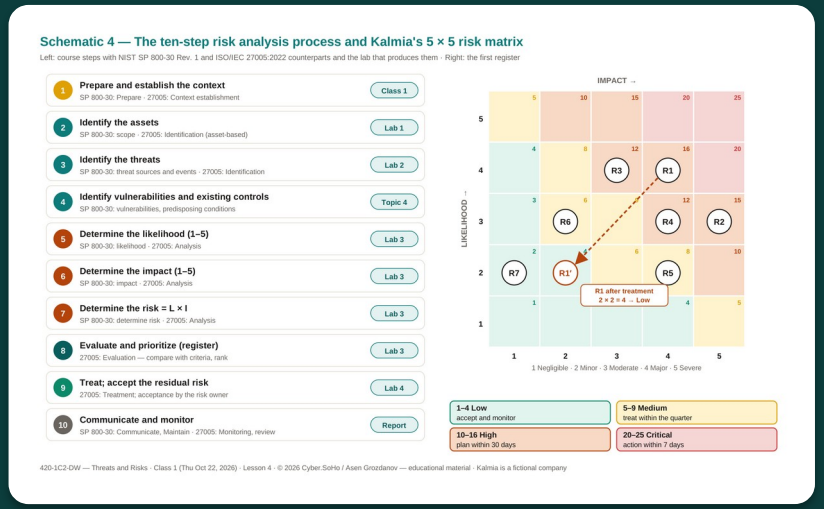
Abbreviations: **CIA** (Confidentiality, Integrity, Availability)

4

Lesson 4 · 0:30 – 0:42

The risk analysis process, step by step

- Ten steps from context to monitoring
- Likelihood and impact scales
- The 5 × 5 matrix and the levels
- Treatment options and residual risk



Schematic 4 — The ten-step risk analysis process and Kalmia's 5 × 5 risk matrix

The process (1/2) — prepare and identify

- **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-30 Rev. 1: prepare · conduct · communicate · maintain
- **ISO/IEC** (International Organization for Standardization / International Electrotechnical Commission) 27005: context · identification · analysis · evaluation · treatment (+ communication, monitoring)
- 1 Prepare: purpose, scope, risk criteria, risk owner — Class 1
- 2 Identify assets: owner, location, value, C-I-A — Lab 1
- 3 Identify threats: sources and events; Cyber Centre, **CVE** (Common Vulnerabilities and Exposures), MITRE **ATT&CK** (Adversarial Tactics, Techniques and Common Knowledge) — Lab 2
- 4 Identify vulnerabilities and existing controls — Topic 4



The process (2/2) — analyse, evaluate, treat, communicate

- 5 Likelihood 1 (rare) to 5 (almost certain)
- 6 Impact 1 (negligible) to 5 (severe)
- 7 Risk = likelihood × impact → level in the matrix
- 8 Evaluate and rank — the risk register (Lab 3); ties: higher impact first
- 9 Treat: reduce · transfer · avoid · accept → residual risk accepted by the risk owner (Lab 4)
- 10 Communicate and monitor: business language; review after any change, at least yearly



Likelihood and impact scales — Kalmia's criteria

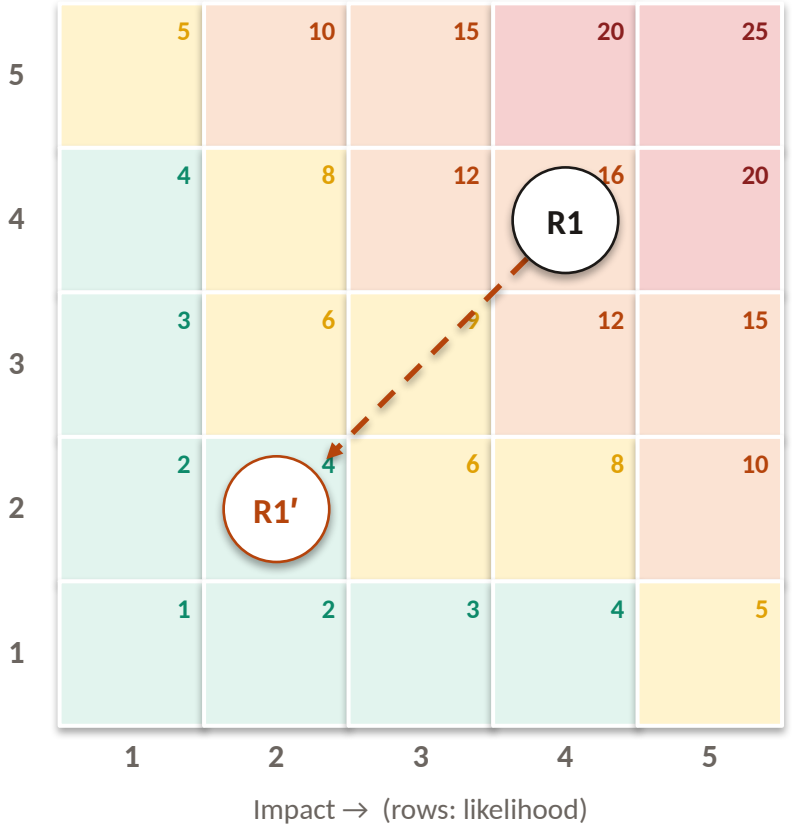
	Likelihood — expected…	Impact — consequence (CAD)
1	Rare — not in 3 years	Negligible — under $1,000
2	Unlikely — once in 2–3 years	Minor — $1,000–$10,000; < 4 h at one site
3	Possible — about once a year	Moderate — $10,000–$50,000; up to 1 day
4	Likely — several times a year	Major — $50,000–$250,000; days; **CAI** (Commission d'accès à l'information du Québec) declaration
5	Almost certain — monthly or now	Severe — over $250,000; survival at stake

Kalmia's risk criteria — fixed in step 1, before any risk is rated
Sized for ≈ $6.8 M of annual revenue · amounts in Canadian dollars · approved by Nadia Roy, the risk owner

The 5 × 5 matrix, the levels and residual risk

Score	Level	Kalmia's rule
1 – 4	Low	Accept and monitor
5 – 9	Medium	Treat within the quarter or justify
10 – 16	High	Plan within 30 days
20 – 25	Critical	Action within 7 days

- R1 ransomware on NAS-01: L 4 × I 4 = 16 → High
- After **MFA** (multi-factor authentication), individual admin accounts, offline tested backup, endpoint protection: 2 × 2 = 4 → Low (residual)
- Scores are ordinal: 16 is worse than 8, not "twice the money" — money needs **SLE** (single loss expectancy) × **ARO** (annualized rate of occurrence) = **ALE** (Topic 5)



Real-life example 4 — Kalmia's first risk register

Rank	Risk	L	I	Score	Level
1	R1 Ransomware encrypts NAS-01 and its attached backup	4	4	16	High
2	R2 Skimming script in the web shop checkout	3	5	15	High
3	R4 Former employee exports the loyalty list	3	4	12	High
4	R3 Fake bank details divert a supplier payment	4	3	12	High
5	R5 ROAST-PC (Windows 10, remote access) compromised	2	4	8	Medium
6	R6 Cloud **POS** (point of sale) outage in a weekend rush	3	2	6	Medium
7	R7 Guest Wi-Fi abused for illegal downloads	2	1	2	Low

4 High risks
R1, R2, R4, R3 → four treatment plans within 30 days

Tie-break rule
R4 before R3: both 12, higher impact first (4 > 3)

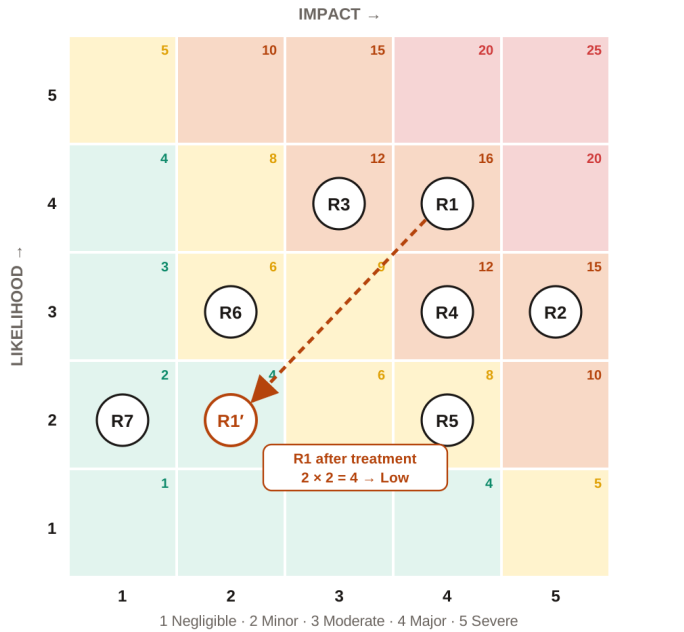
Residual risk of R1
After treatment 2 × 2 = 4 → Low; Nadia Roy accepts it in Lab 4

Schematic 4 — Ten steps and Kalmia's 5 × 5 matrix

Schematic 4 — The ten-step risk analysis process and Kalmia's 5 × 5 risk matrix

Left: course steps with NIST SP 800-30 Rev. 1 and ISO/IEC 27005:2022 counterparts and the lab that produces them · Right: the first register

1	**Prepare and establish the context** SP 800-30: Prepare · 27005: Context establishment	Class 1
2	**Identify the assets** SP 800-30: scope · 27005: Identification (asset-based)	Lab 1
3	**Identify the threats** SP 800-30: threat sources and events · 27005: Identification	Lab 2
4	**Identify vulnerabilities and existing controls** SP 800-30: vulnerabilities, predisposing conditions	Topic 4
5	**Determine the likelihood (1–5)** SP 800-30: likelihood · 27005: Analysis	Lab 3
6	**Determine the impact (1–5)** SP 800-30: impact · 27005: Analysis	Lab 3
7	**Determine the risk = L × I** SP 800-30: determine risk · 27005: Analysis	Lab 3
8	**Evaluate and prioritize (register)** 27005: Evaluation — compare with criteria, rank	Lab 3
9	**Treat; accept the residual risk** 27005: Treatment; acceptance by the risk owner	Lab 4
10	**Communicate and monitor** SP 800-30: Communicate, Maintain · 27005: Monitoring, review	Report



1–4 Low — accept and monitor

5–9 Medium — treat within the quarter

10–16 High — plan within 30 days

20–25 Critical — action within 7 days

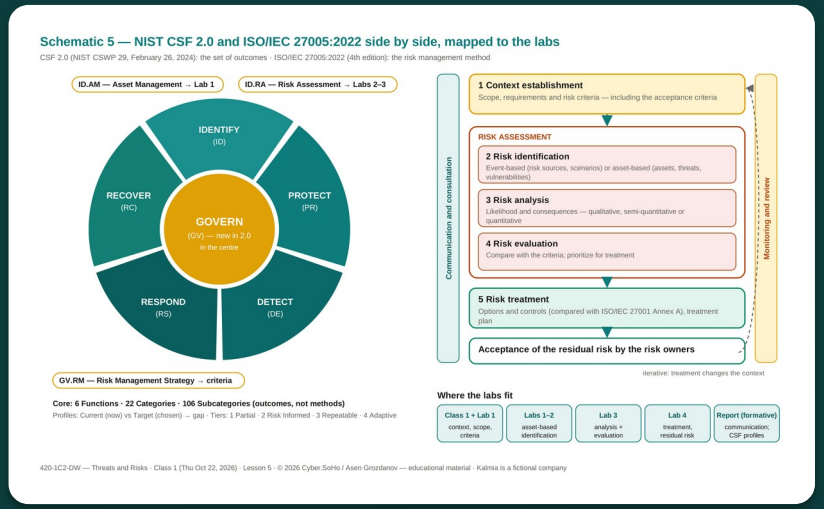
420-1C2-DW — Threats and Risks · Class 1 (Thu Oct 22, 2026) · Lesson 4 · © 2026 Cyber.SoHo / Asen Grozdanov — educational material · Kalmia is a fictional company

5

Lesson 5 · 0:42 – 0:52

Risk analysis frameworks — NIST CSF 2.0 and ISO/IEC 27005

- What a framework is; who publishes NIST CSF and ISO/IEC 27005
- CSF 2.0: Functions, Core, Profiles, Tiers
- ISO/IEC 27005:2022: the process
- How they fit — and where the labs fit

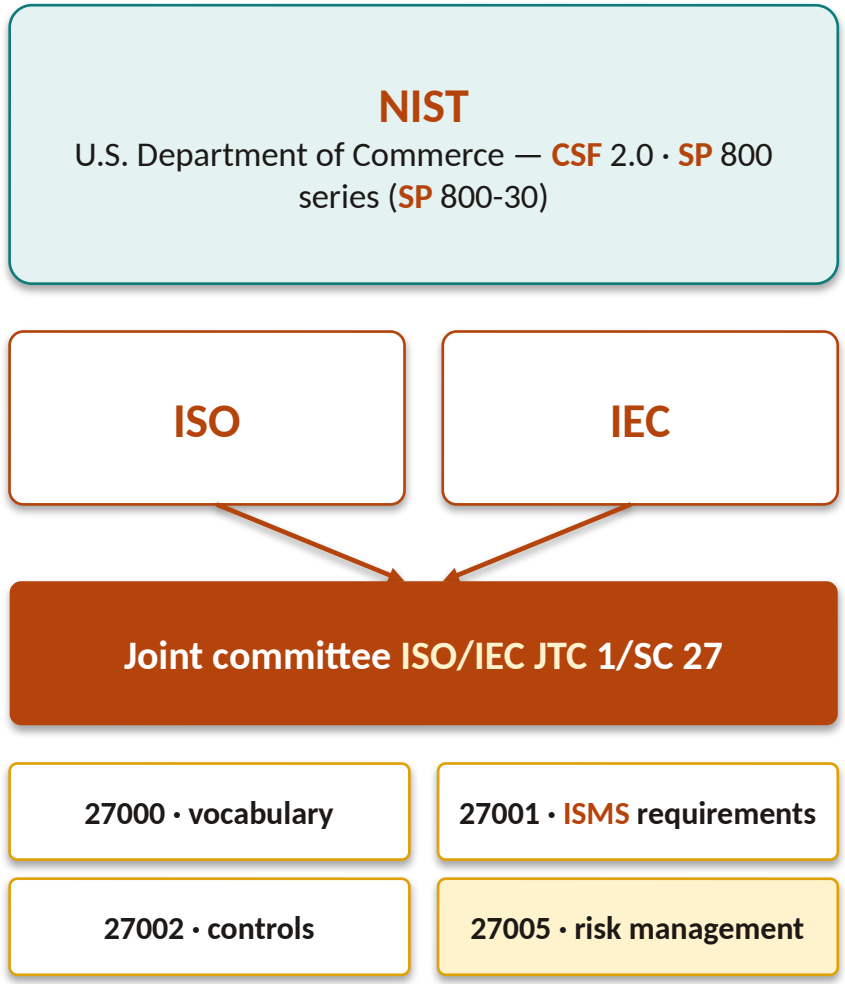


Schematic 5 — NIST CSF 2.0 and ISO/IEC 27005:2022 side by side, mapped to the labs

Abbreviations: CSF (Cybersecurity Framework) · ISO/IEC (International Organization for Standardization / International Electrotechnical Commission) · NIST (National Institute of Standards and Technology)

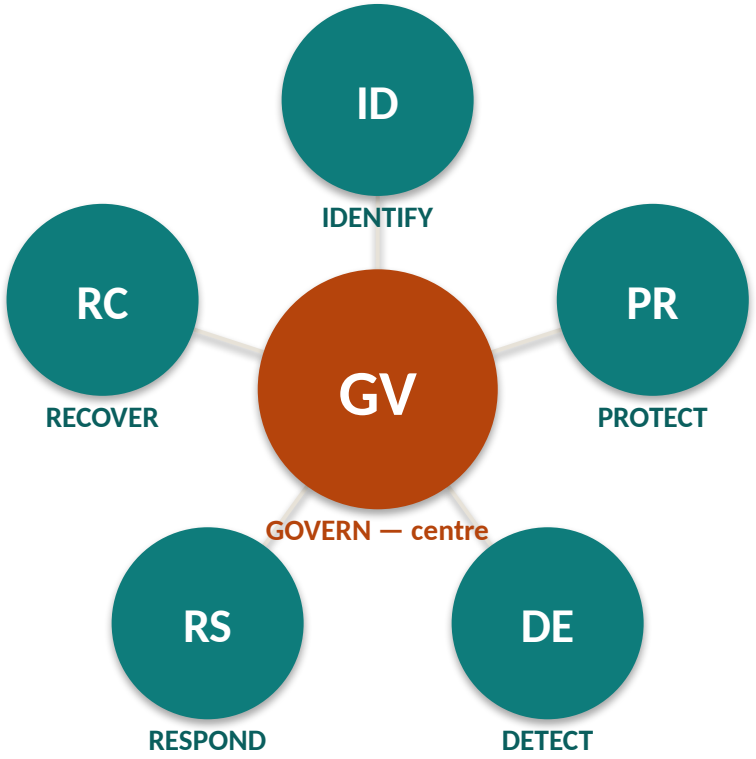
Frameworks, standards and the bodies behind them

- Framework: a published, structured set of outcomes, practices or steps — and a common language
- Standard: approved by consensus; certifiable (**ISO/IEC** (International Organization for Standardization / International Electrotechnical Commission) 27001) or guidance (**ISO/IEC** 27005)
- **NIST** (National Institute of Standards and Technology): non-regulatory agency of the U.S. Department of Commerce — **CSF** (Cybersecurity Framework), **SP** (Special Publication) 800 series
- **ISO** (International Organization for Standardization) + **IEC** (International Electrotechnical Commission): joint committee **ISO/IEC JTC** (Joint Technical Committee) 1/SC 27 — the **ISO/IEC** 27000 family
  - 27000 vocabulary · 27001 **ISMS** (information security management system) requirements · 27002 controls · 27005 risk management



NIST CSF 2.0 (1/2) — six Functions

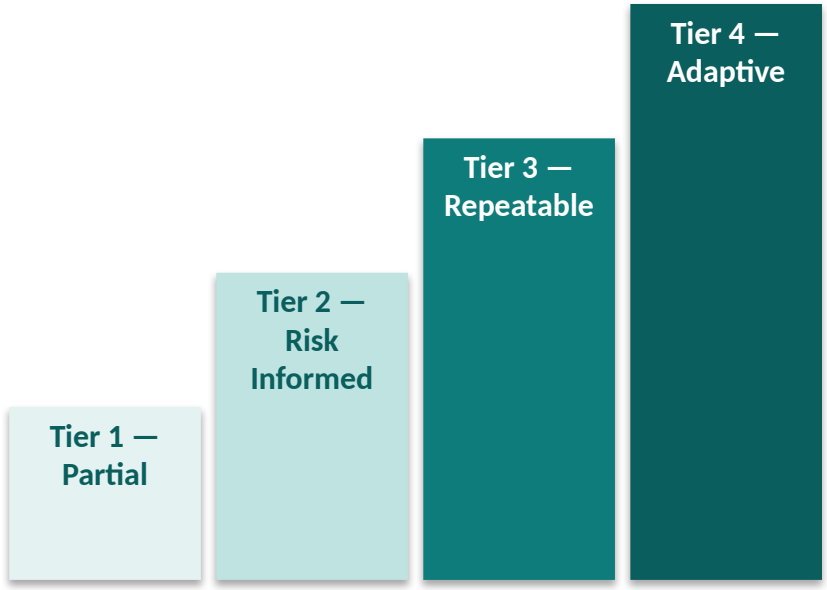
Function	Outcome (paraphrased)
GOVERN (GV)	Strategy, expectations and policy set, communicated, monitored
IDENTIFY (ID)	Current risks to assets, suppliers, operations understood
PROTECT (PR)	Safeguards used to manage the risks
DETECT (DE)	Possible attacks and compromises found and analysed
RESPOND (RS)	Actions taken about a detected incident
RECOVER (RC)	Affected assets and operations restored



Abbreviations: **CSF** (Cybersecurity Framework) · **NIST** (National Institute of Standards and Technology)

NIST CSF 2.0 (2/2) — Core, Profiles and Tiers

- Core: 6 Functions → 22 Categories → 106 Subcategories (outcomes, not methods)
- ID.AM-01 hardware inventory · ID.AM-02 software and services inventory → Lab 1
- ID.RA-04 impacts and likelihoods identified and recorded → Lab 3
- Current Profile: outcomes achieved now · Target Profile: outcomes chosen · difference = gap
- Tiers: 1 Partial · 2 Risk Informed · 3 Repeatable · 4 Adaptive
- Quick Start Guides — small business (**NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 1300)



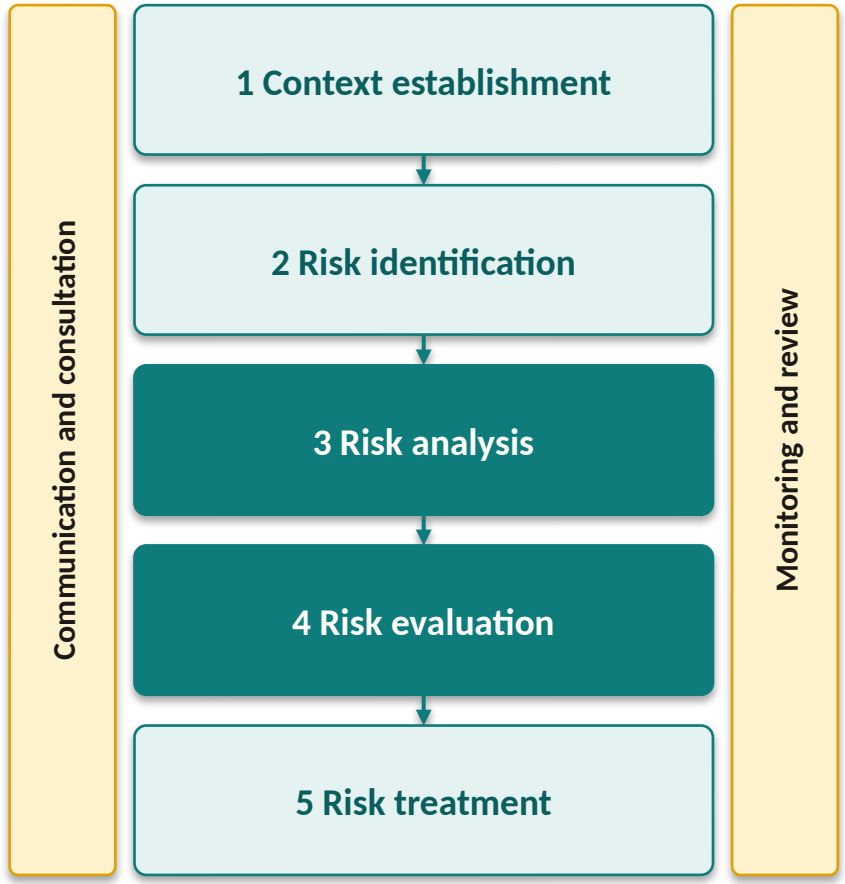
Tiers: rigour of cybersecurity risk governance and management

Current Profile → Target Profile
the difference is the gap → action plan

Abbreviations: **CSF** (Cybersecurity Framework)

ISO/IEC 27005:2022 — the risk management process

- 4th edition, October 2022; supports an **ISMS** (information security management system) based on **ISO/IEC** (International Organization for Standardization / International Electrotechnical Commission) 27001; adapts **ISO** (International Organization for Standardization) 31000
- 1 Context establishment — scope and risk criteria
- 2 Risk identification — event-based or asset-based
- 3 Risk analysis — likelihood and consequences
- 4 Risk evaluation — compare with criteria, prioritize
- 5 Risk treatment — options, controls vs Annex A of 27001, residual risk accepted by risk owners
- Throughout: communication and consultation · monitoring and review
- **ISO/IEC** 27005 = the method · **CSF** (Cybersecurity Framework) 2.0 = the set of outcomes



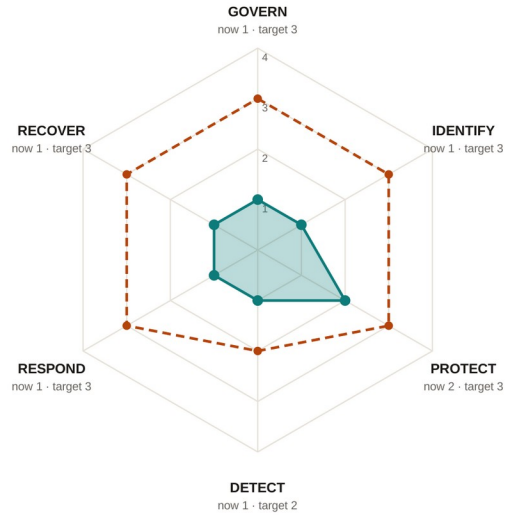
assessment = identification + analysis + evaluation

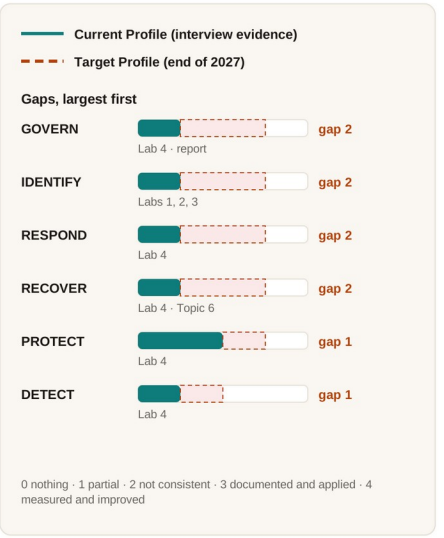
Real-life example 5 — Kalmia's Current vs Target Profile

Function	Now	Target	Gap	Lab
GOVERN	1	3	2	Lab 4
IDENTIFY	1	3	2	Labs 1–3
PROTECT	2	3	1	Lab 4
DETECT	1	2	1	Lab 4
RESPOND	1	3	2	Lab 4
RECOVER	1	3	2	Lab 4

Graph 5 — Kalmia's Current Profile against its Target Profile (first look, course scale 0–4)

Evidence from the first interview · target chosen by Nadia Roy for the end of 2027 · the 0–4 scale is a course convention, not part of the CSF

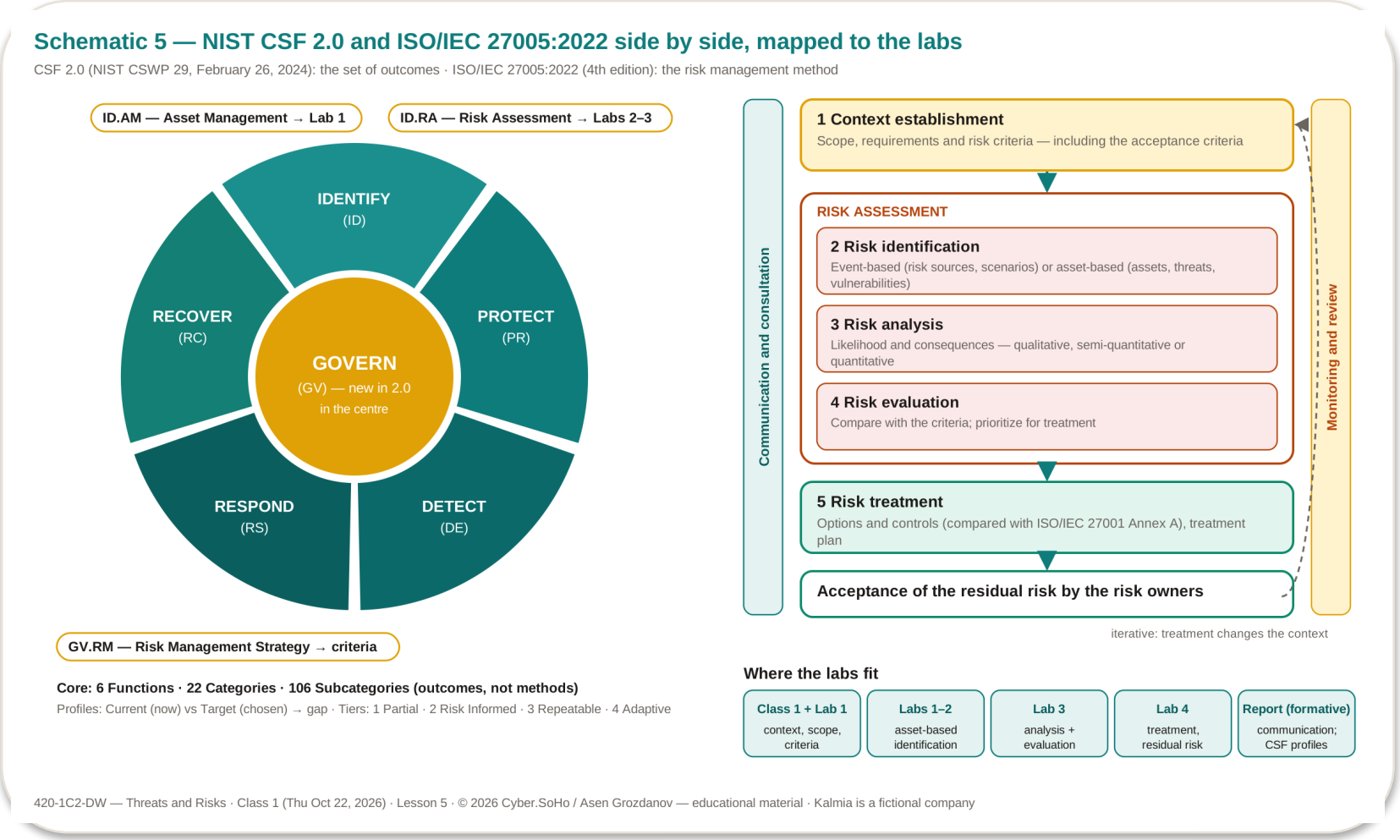




420-1C2-DW — Threats and Risks · Class 1 (Thu Oct 22, 2026) · Lesson 5 · © 2026 Cyber.SoHo / Asen Grozdanov — educational material · Kalmia is a fictional company

Largest gaps (2 points): GOVERN, IDENTIFY, RESPOND, RECOVER
Labs 1 to 3 close the IDENTIFY gap; Lab 4 proposes measures for the others — the 0–4 scale is a course convention

Schematic 5 — CSF 2.0 and ISO/IEC 27005 side by side



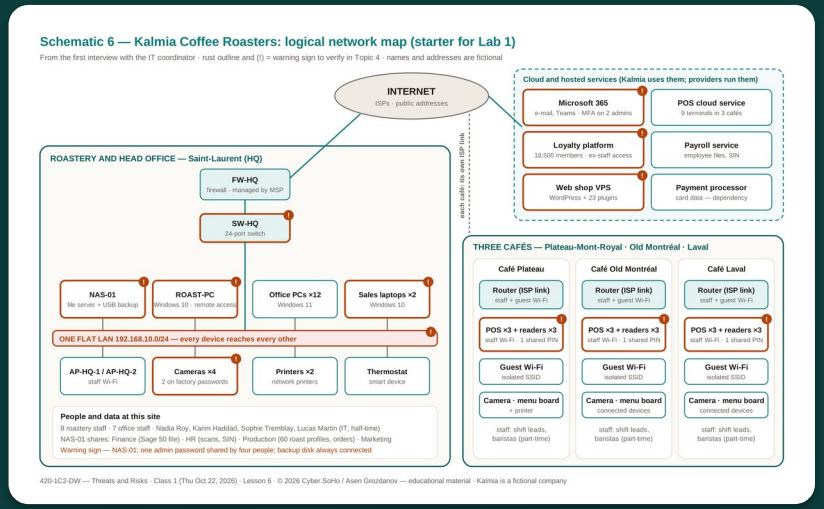
Abbreviations: **CSF** (Cybersecurity Framework) · **ISO/IEC** (International Organization for Standardization / International Electrotechnical Commission)

6

Lesson 6 · 0:52 – 1:00

The case organization of the Integrative Project — Kalmia Coffee Roasters

- The company, its people and sites
- Systems and data
- What the owner worries about
- First warning signs



Schematic 6 — Kalmia: logical network map (starter for Lab 1)

Kalmia at a glance (1/2) — business and people

- Torréfaction Kalmia inc. — Kalmia Coffee Roasters Inc. (fictional), founded 2014
- Roastery, office and warehouse in Saint-Laurent; cafés on the Plateau, in Old Montréal, in Laval
- 46 employees · about $6.8 M revenue: cafés 40% · wholesale 35% · web shop 25%
- Nov–Dec: about one third of the year's online revenue
- Nadia Roy — President and **CEO** (chief executive officer), risk owner, person in charge of personal information
- Karim Haddad — Operations · Sophie Tremblay — Finance and **HR** (human resources) · Lucas Martin — **IT** (half-time)
- External: **MSP** (managed service provider), web developer, hosting provider, **POS** (point of sale) / loyalty / payroll **SaaS** (software as a service), payment processor

Revenue ≈ $6.8 M — three streams



Nov–Dec ≈ one third of the year's online revenue

46
employees

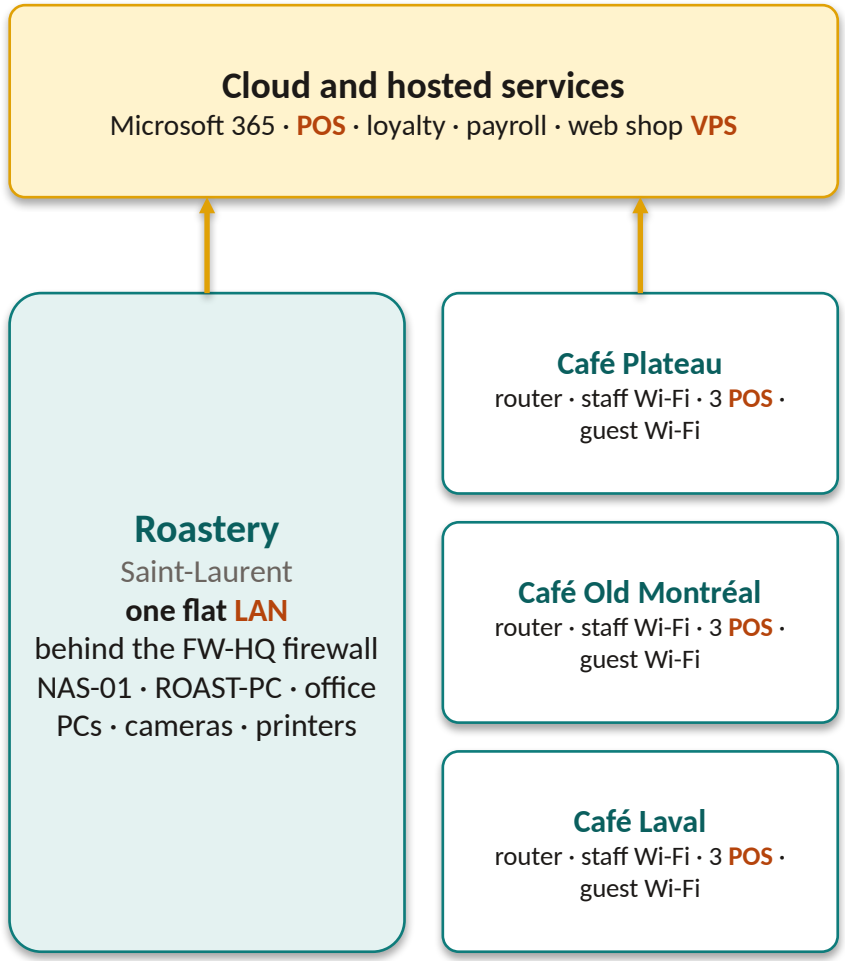
4
sites

18,500
loyalty members

≈ 2,300
online subscribers

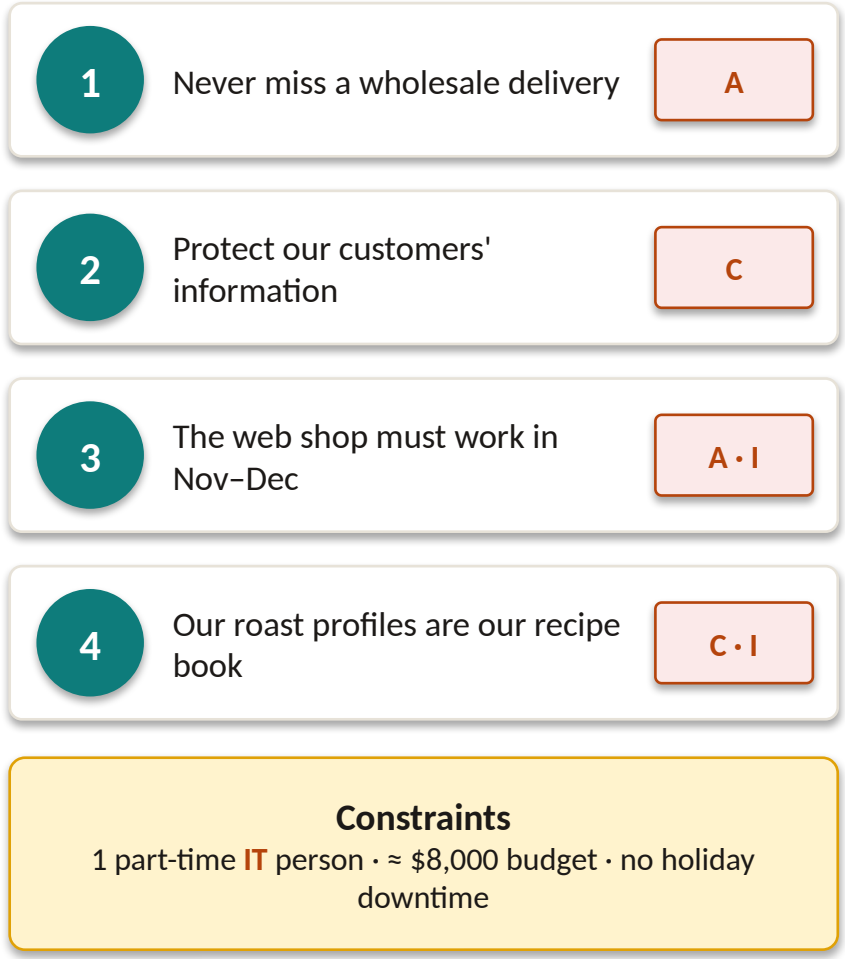
Kalmia at a glance (2/2) — systems and data

- Roastery: one flat **LAN** (local area network) behind FW-HQ — office PCs, NAS-01, ROAST-PC, cameras, printers
- Cafés: **ISP** (Internet service provider) router, staff Wi-Fi (3 **POS** (point of sale) tablets each), separate guest Wi-Fi
- 15 computers (12 Windows 11; 2 sales laptops and ROAST-PC on Windows 10)
- 9 **POS** tablets, 9 card readers, 7 cameras, 3 printers, menu boards
- Web shop: WordPress + WooCommerce, 23 plugins, **VPS** (virtual private server) in Montréal
- Microsoft 365 · loyalty, **POS** and payroll as **SaaS** (software as a service)
- Personal information: 18,500 loyalty members · ~2,300 subscribers · employees (**SIN** (Social Insurance Number), bank)
- Card numbers: never stored by Kalmia (processor tokens)
- Business secrets: 60 roast profiles · wholesale prices · daily order plan



What matters most to the owner — priorities and constraints

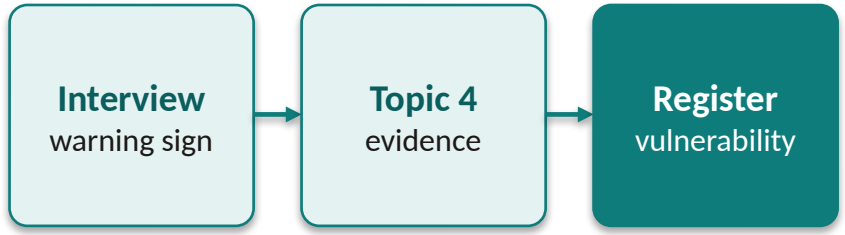
- 1 “Never miss a wholesale delivery.” — availability
- 2 “Protect our customers' information.” — confidentiality, Québec's law
- 3 “The web shop must work in November and December.” — availability and integrity
- 4 “Our roast profiles are our recipe book.” — confidentiality and integrity
- Constraints: one part-time **IT** (information technology) person · about $8,000 security budget this year
- No downtime in the holiday season · no measure may slow the café counter



First warning signs — to verify in Topic 4

- ROAST-PC: Windows 10 (no free updates since Oct 14, 2025) + unattended remote access
- Flat roastery network
- NAS-01: shared admin password; backup disk always connected
- **MFA** (multi-factor authentication) only on two Microsoft 365 admin accounts
- 4 outdated web shop plugins; admin accounts without **MFA**
- No offboarding checklist
- 2 cameras on factory passwords · one manager **PIN** (personal identification number) per café
- No incident response plan
- Warning signs are not conclusions: evidence first (Topic 4)

9 **warning signs from one interview**



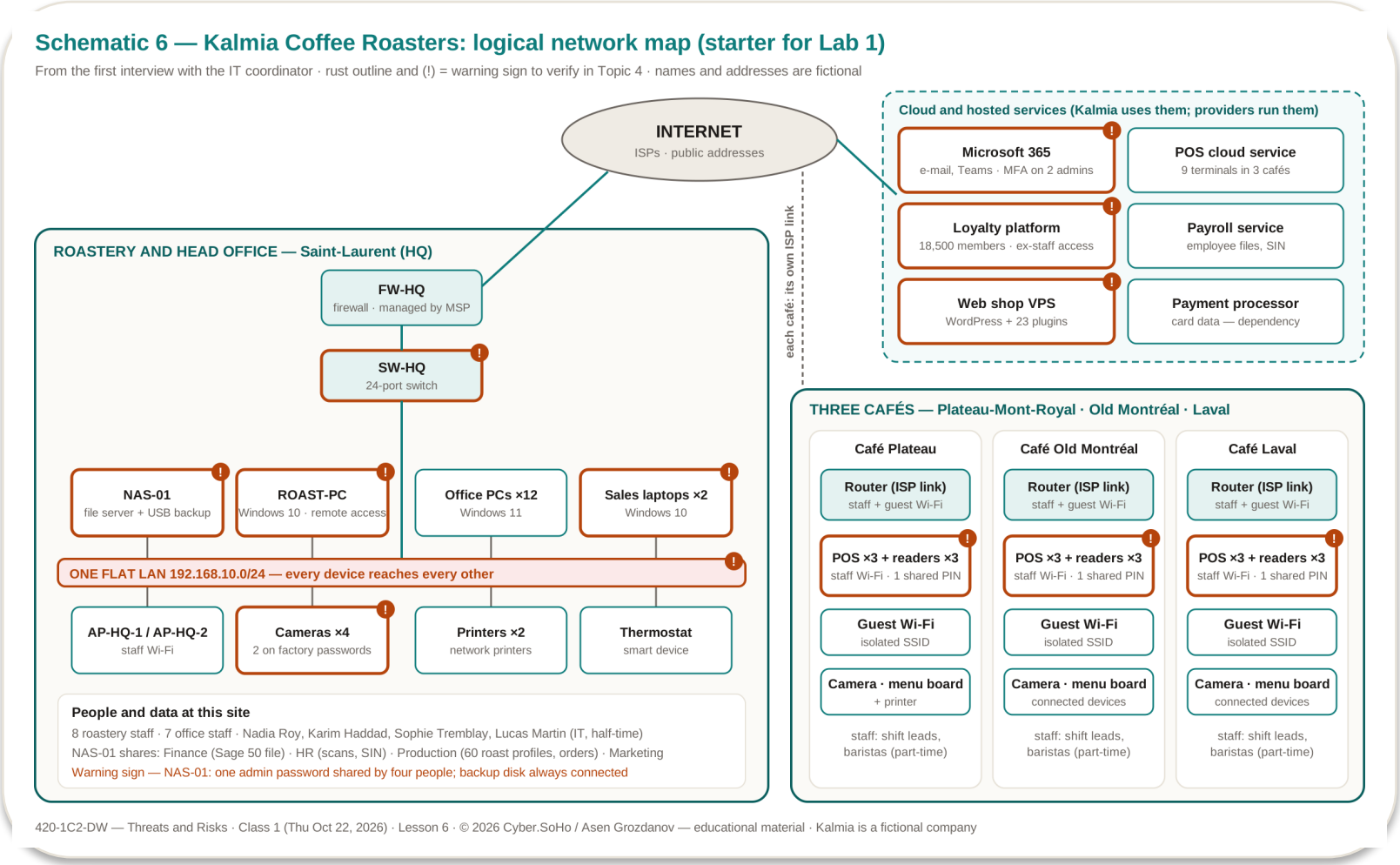
A sign becomes a vulnerability only when evidence confirms it.

Real-life example 6 — ten answers, a starter asset list

#	Question	Assets recorded	⚑ Warning sign
2	How is the roastery connected?	FW-HQ, SW-HQ, 2 access points	Flat network
3	Where are the files?	NAS-01, backup disk	Backup always connected
4	Which computers?	15 computers incl. ROAST-PC	Windows 10, remote access
5	How do cafés take payments?	9 tablets, 9 readers, 3 routers	Shared **PIN** (personal identification number)
6	Where is the web shop?	**VPS** (virtual private server): WordPress, 23 plugins	Outdated plugins, no **MFA** (multi-factor authentication)
7	Which cloud services?	4 **SaaS** (software as a service) services	**MFA** limited
8	What else is connected?	Cameras, thermostat, printers, boards	Default passwords
9	What happens when someone leaves?	(procedure)	No offboarding

Ten answers → about 25 asset rows in six types and 9 warning signs — and no conclusions yet
Lab 1 starts on Saturday from this list and verifies it with a scan of the Kalmia lab replica

Schematic 6 — Kalmia: logical network map (starter for Lab 1)



Videos for tonight (1/2) — Lessons 1 to 3

Lesson 1 — **Risk Management — CompTIA Security+ SY0-701 — 5.2**

Professor Messer · 3 min 30 s — ▶️ Watch on YouTube

Lesson 1 — **Risk Management Strategies — CompTIA Security+ SY0-701 — 5.2**

Professor Messer · 3 min 12 s — ▶️ Watch on YouTube

Lesson 2 — **What Are Threats, Risks, & Vulnerabilities in Cybersecurity? | Google Cybersecurity Certificate**

Grow with Google · about 5 min — ▶️ Watch on YouTube

Lesson 2 — **Cybersecurity Risk vs Threat vs Vulnerability | What's the Difference?**

Cybersecurity Dojo · about 3.5 min — ▶️ Watch on YouTube

Lesson 2 — **Security Controls — CompTIA Security+ SY0-701 — 1.1**

Professor Messer · 11 min 48 s — ▶️ Watch on YouTube

Lesson 3 — **The CIA Triad — CompTIA Security+ SY0-701 — 1.2**

Professor Messer · 5 min 17 s — ▶️ Watch on YouTube

Lesson 3 — **Cybersecurity Architecture: Fundamentals of Confidentiality, Integrity, and Availability**

IBM Technology · about 12 min — ▶️ Watch on YouTube

Abbreviations: **CIA** (Confidentiality, Integrity, Availability)

Videos for tonight (2/2) — Lessons 4 to 6

Lesson 4 — **Risk Analysis — CompTIA Security+ SY0-701 — 5.2**

Professor Messer · 9 min 13 s — ▶️ Watch on YouTube

Lesson 4 — **Business Impact Analysis — CompTIA Security+ SY0-701 — 5.2**

Professor Messer · 2 min 55 s — ▶️ Watch on YouTube

Lesson 5 — **The NIST Cybersecurity Framework (CSF) 2.0**

National Institute of Standards and Technology · about 3 min — ▶️ Watch on YouTube

Lesson 5 — **NIST CSF 2.0: The 6 Core Functions Explained**

BeyondTrust · 2 min 04 s — ▶️ Watch on YouTube

Lesson 5 — **What is ISO/IEC 27005?**

Standarity · 10 min 51 s — ▶️ Watch on YouTube

Lesson 6 — **Get Cyber Safe | Point of sale device security for your small business**

Communications Security Establishment (Get Cyber Safe) · 1 min 14 s — ▶️ Watch on YouTube

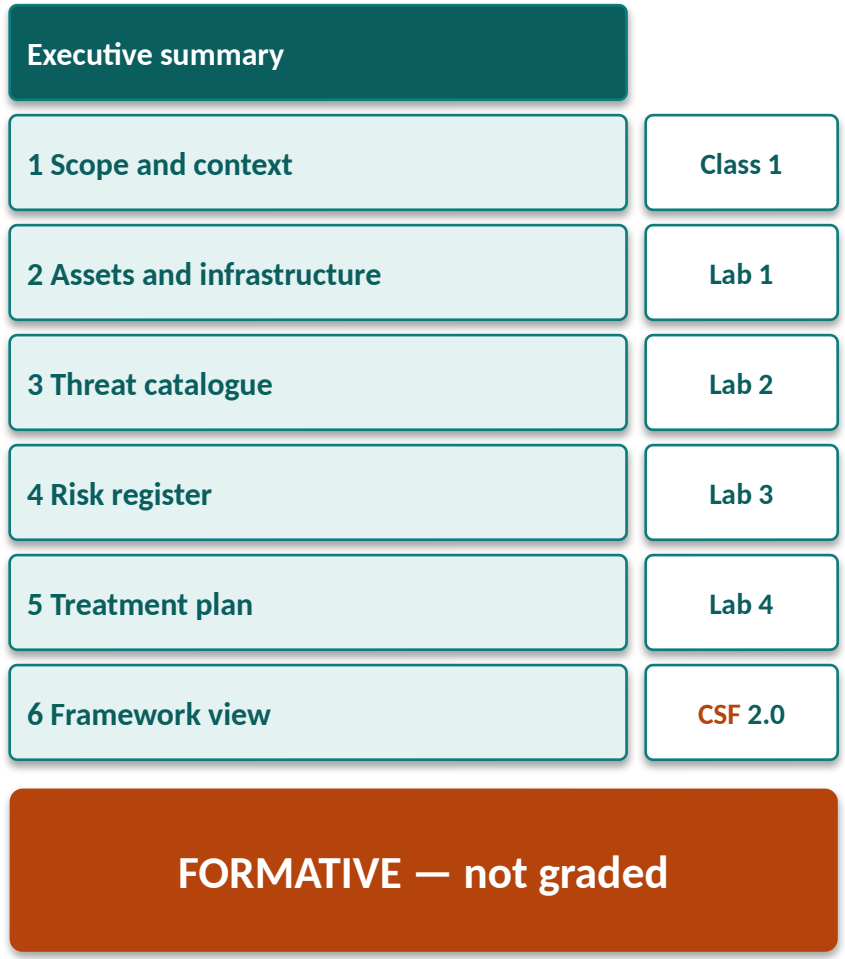
Lesson 6 — **Threat Actors — CompTIA Security+ SY0-701 — 2.1**

Professor Messer · 10 min 23 s — ▶️ Watch on YouTube

Abbreviations: **CSF** (Cybersecurity Framework) · **ISO/IEC** (International Organization for Standardization / International Electrotechnical Commission) · **NIST** (National Institute of Standards and Technology)

The Integrative Project — what it must provide (FORMATIVE)

- Executive summary — top risks and measures, in business language
- 1 Scope and context — owner's question, scope, dependencies, risk criteria
- 2 Assets and infrastructure — inventory, C-I-A classification, network map, permissions (Lab 1)
- 3 Threat catalogue — sources, motivations, events, public sources used (Lab 2)
- 4 Risk register and prioritization (Lab 3)
- 5 Treatment and prevention plan — options, controls, cost/benefit, residual risk (Lab 4)
- 6 Framework view — **CSF** (Cybersecurity Framework) 2.0 Current vs Target Profile; **ISO/IEC** (International Organization for Standardization / International Electrotechnical Commission) 27005 process
- Optional presentation — Thursday, November 26, online
- FORMATIVE: not graded — the labs are graded on their own (5% each)



Before Class 2 — Friday, October 23, 6–10 pm

- Watch the videos of Lessons 2 and 6; redo the flash-cards
- Create your free **BAnQ** (Bibliothèque et Archives nationales du Québec) account
- Read “Inventory your assets” — Get Cyber Safe Guide for Small Businesses
- Read sections 7.3 and 7.6 of the Legal Notice (**Nmap** (Network Mapper) on Friday — lab replica only)
- Check that you can open a spreadsheet and diagrams.net
- Quiz 1 (Topics 1–2, 5%) — online, Saturday, October 24

OCT
23

Friday · 6–10 pm

Class 2 — Topic 2: hardware and software inventories, hands-on **Nmap** (lab replica)

OCT
24

Saturday · online

Quiz 1 — Topics 1 and 2 (5%) · Lab 1 starts

Key references — official sites

- **NIST** (National Institute of Standards and Technology) Cybersecurity Framework — nist.gov/cyberframework
- **NIST SP** (Special Publication) 800-30 Rev. 1 — csrc.nist.gov
- **ISO/IEC** (International Organization for Standardization / International Electrotechnical Commission) 27005:2022 — iso.org/standard/80585.html · **IEC** (International Electrotechnical Commission) — iec.ch
- Canadian Centre for Cyber Security — cyber.gc.ca
- Get Cyber Safe — getcybersafe.gc.ca
- Commission d'accès à l'information du Québec — cai.gouv.qc.ca
- **CVE** (Common Vulnerabilities and Exposures) — cve.org · MITRE **ATT&CK** (Adversarial Tactics, Techniques and Common Knowledge) — attack.mitre.org
- Cyber.SoHo Legal Notice v2.0 — cyber-soho.github.io
- Check every link with VirusTotal before clicking (Annex C)

1 **Read the address**

Is it the official domain you expect?

2 **VirusTotal**

Paste the **URL** at virustotal.com

3 **Google Safe Browsing**

Check the site status

? **If in doubt, ask**

Annex C, step 8 — before you click

Abbreviations: **URL** (Uniform Resource Locator)

Thank you — questions?

Next: Friday, October 23, 2026, 6–10 pm, online
Topic 2 — hardware and software inventories, classification, hands-on **Nmap** on the Kalmia lab replica



Quiz 1 (Topics 1 and 2, 5%) — online, Saturday, October 24

Educational Hub © 2026 | From the Industry to the Classroom — Building the IT's Future, Today and Together !
ALL Rights Reserverd